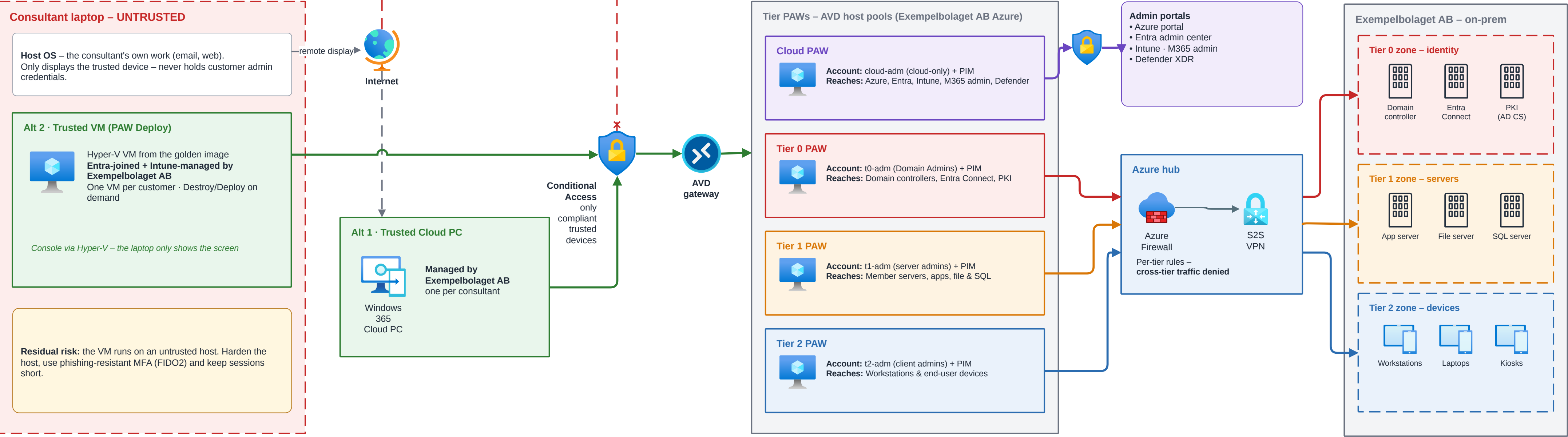


Exempelbolaget AB – PAW overview: chain of trust and one PAW per tier

Untrusted consultant laptop → trusted access device (managed by the customer) → tier PAW → target

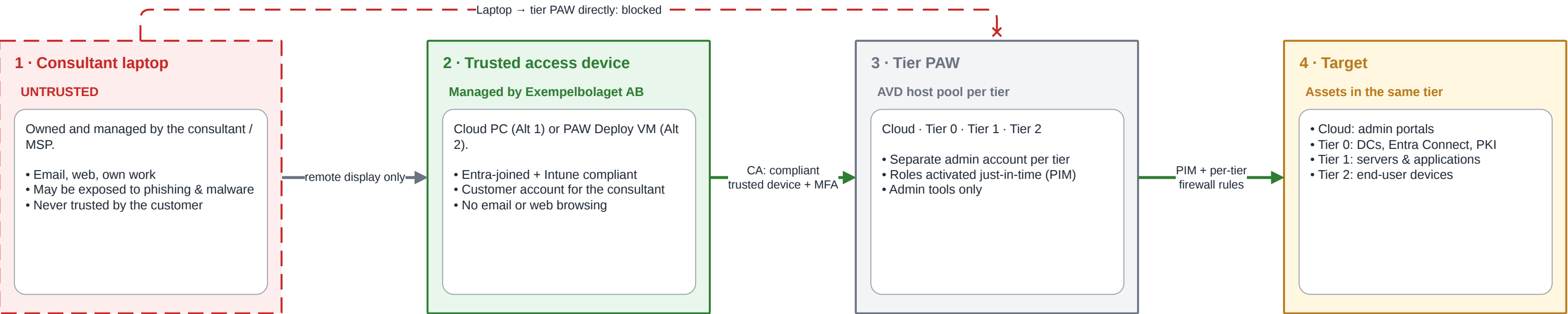


Chain of trust: every hop is only allowed from the layer before it. — ✖ blocked — trusted path — Cloud — Tier 0 — Tier 1 — Tier 2 - - - remote display only

Same tier PAWs in both alternatives – only the trusted access device differs: a Cloud PC (Alt 1) or a PAW Deploy VM (Alt 2), so the consultant does not have to carry one laptop per customer.

What is a Privileged Access Workstation (PAW)?

Clean source: the device you connect from must be at least as trusted as what you connect to



PAW principles

Clean source
Anything that controls an asset must be as trustworthy as the asset itself.

Separate identity
One admin account per tier – only usable from that tier's PAW.

Just-in-time privileges
Admin roles are activated through PIM – time-bound and approved.

Device as a control
Conditional Access only accepts the customer's compliant trusted device.

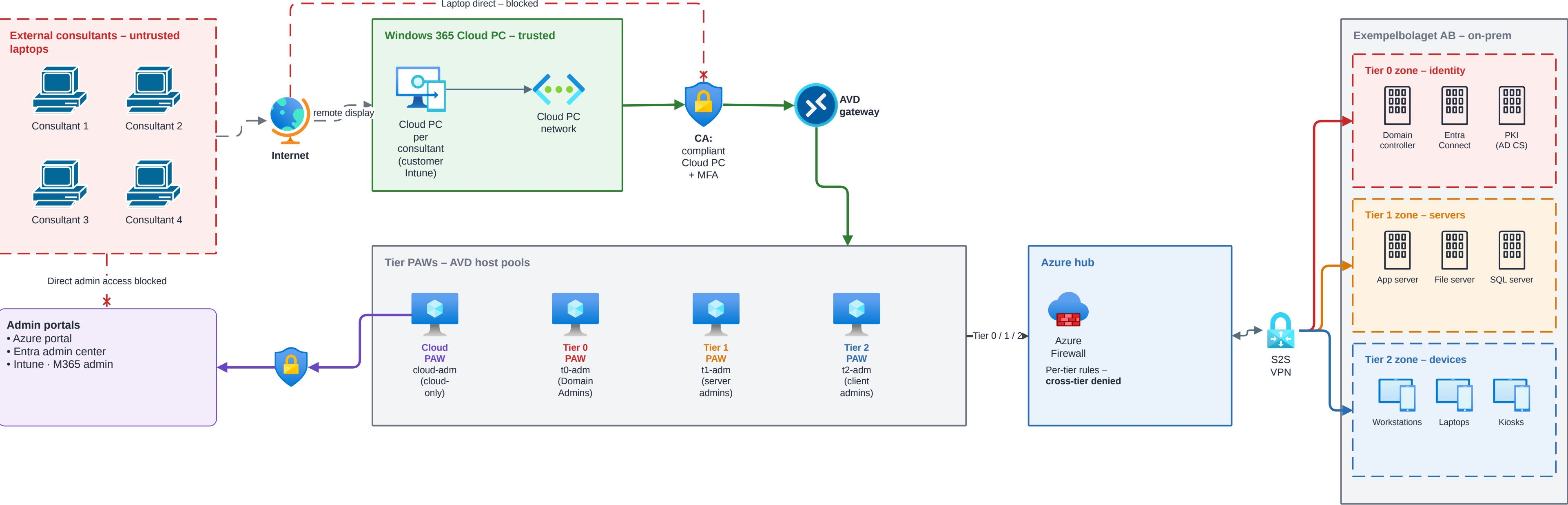
Two ways to deliver the trusted access device

Alternative 1 – Windows 365 Cloud PC
A Cloud PC in the customer's tenant; the laptop only shows the remote screen.

Alternative 2 – PAW Deploy
A Hyper-V VM on the laptop, enrolled in the customer's Entra ID and Intune – no extra hardware per customer.

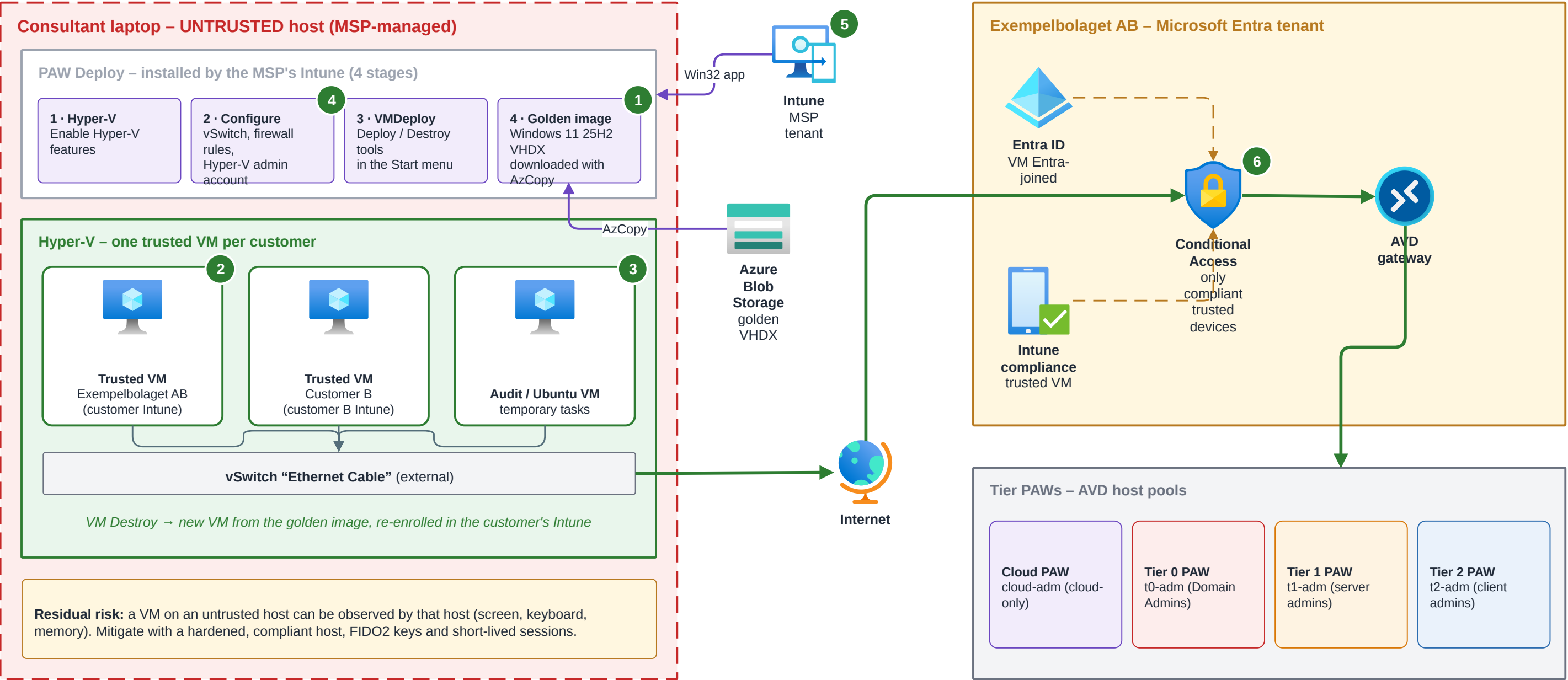
Alternative – Windows 365 Cloud PC as the trusted access device

Exempelbolaget AB – consultants reach the tier PAWs only from a Cloud PC the customer manages



Alternative – PAW Deploy: a trusted VM per customer on the consultant's laptop

The laptop stays untrusted – the VM is enrolled in and managed by Exempelbolaget AB



Targets and network paths: see 0 · Overview

How PAW Deploy supports security

- 1 Known-good golden image**
Every VM starts from the same versioned Windows 11 VHDX – the version is tracked in the registry.
- 2 Customer-managed trusted VM**
Each VM is enrolled in that customer's Entra ID and Intune – the customer decides what is compliant.
- 3 Disposable by design**
VM Destroy + Deploy gives a clean machine instead of patching one that has drifted.
- 4 Hardened host**
Hyper-V remote management firewall rules disabled; separate local Hyper-V admin account (15+ chars).
- 5 Intune-deployed & versioned**
Identical install on every consultant laptop, with registry-based detection and upgrades.
- 6 Conditional Access as the gate**
Tier PAWs only accept a compliant trusted device – never the laptop itself.

Alternative 1 vs Alternative 2

Same tier PAWs – the difference is the trusted access device

	Alt 1 – Windows 365 Cloud PC	Alt 2 – PAW Deploy VM
Trusted access device	Cloud PC in the customer's tenant	Hyper-V VM on the laptop, enrolled in the customer's tenant
What the laptop does	Only shows the remote screen of the Cloud PC	Runs the VM – the host must be hardened
Cost model	Windows 365 licence per consultant and customer	No per-VM cloud cost – existing hardware + blob storage for the image
Isolation between customers	One Cloud PC per consultant per customer	One VM per customer, all from the same golden image
Reset / lifecycle	Reset / reprovision in Windows 365	VM Destroy + Deploy – a fresh VM in minutes
Connectivity	Internet needed for every session	The VM runs locally; internet needed to reach the tier PAWs
Hardware requirements	Any device with a supported client	Hyper-V capable CPU, enough RAM and ~20 GB+ disk per image
Tier PAWs & targets	AVD host pool per tier – identical in both	AVD host pool per tier – identical in both

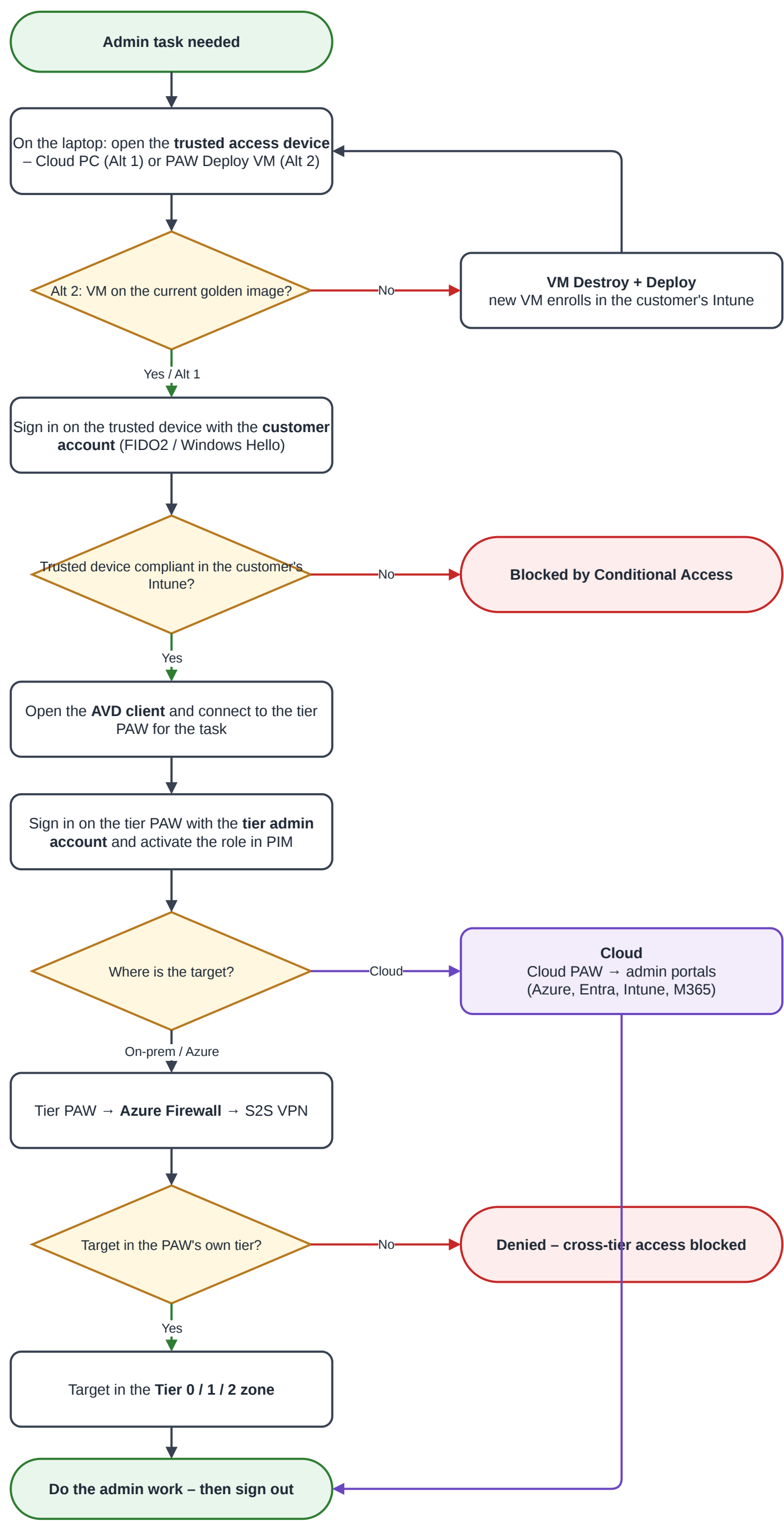
What each machine can reach

Each layer is only reachable from the layer before it



Access flow – from consultant laptop to target

The same flow for every tier – only the tier PAW, the admin account and the firewall rule change



Why this works

- The laptop never connects to a tier PAW – Conditional Access only accepts the customer's compliant trusted device.
- Each tier PAW is its own AVD host pool with its own admin account.
- Azure Firewall lets each tier PAW reach only its own zone, so a compromised Tier 2 PAW cannot reach Tier 1 or Tier 0.